

SAST Assignment –Lab 4 Report

1.semgrep-rules.yml code/

```
rules:
  # =====
  #  SQL INJECTION - BAD
  # =====
  - id: mutillidae-php-sqli-raw
    message: "Possible SQL injection: raw user input used inside SQL query"
    severity: ERROR
    languages: [php]
    patterns:
      - pattern: mysqli_query($CONN, $QUERY)
      - metavariable-pattern:
          metavariable: $QUERY
          pattern-regex: '(\$_GET\[["'\^"]+\]|\\$_POST\[["'\^"]+\])'
    metadata:
      cwe: "CWE-89"
      category: "sqli"

  - id: mutillidae-php-xss-echo
    message: "Possible XSS: echoing unsanitized user input"
    severity: ERROR
    languages: [php]
    patterns:
      - pattern: echo $X;
      - metavariable-pattern:
          metavariable: $X
          pattern-regex: '(\$_GET\[["'\^"]+\]|\\$_POST\[["'\^"]+\])'
    metadata:
      cwe: "CWE-79"
      category: "xss"
```

2.tests

*test-sqli-bad.php/

```
<?php
$conn = mysqli_connect("localhost","root","","db");
$query = "SELECT * FROM users WHERE username='" . $_POST['user'] . "'";
mysqli_query($conn, $query);
?>
```

*test-sqli-good.php/

```
<?php
$conn = mysqli_connect("localhost","root","","db");
$stmt = $conn->prepare("SELECT * FROM users WHERE username=?");
$stmt->bind_param("s", $_POST['user']);
$stmt->execute();
?>
```

*test-xss-bad.php/

```
<?php
echo "Hello " . $_GET['username'];
?>
```

*test-xss-good.php/

```
<?php
echo "Hello " . htmlspecialchars($_GET['username'], ENT_QUOTES, 'UTF-8');
?>
```

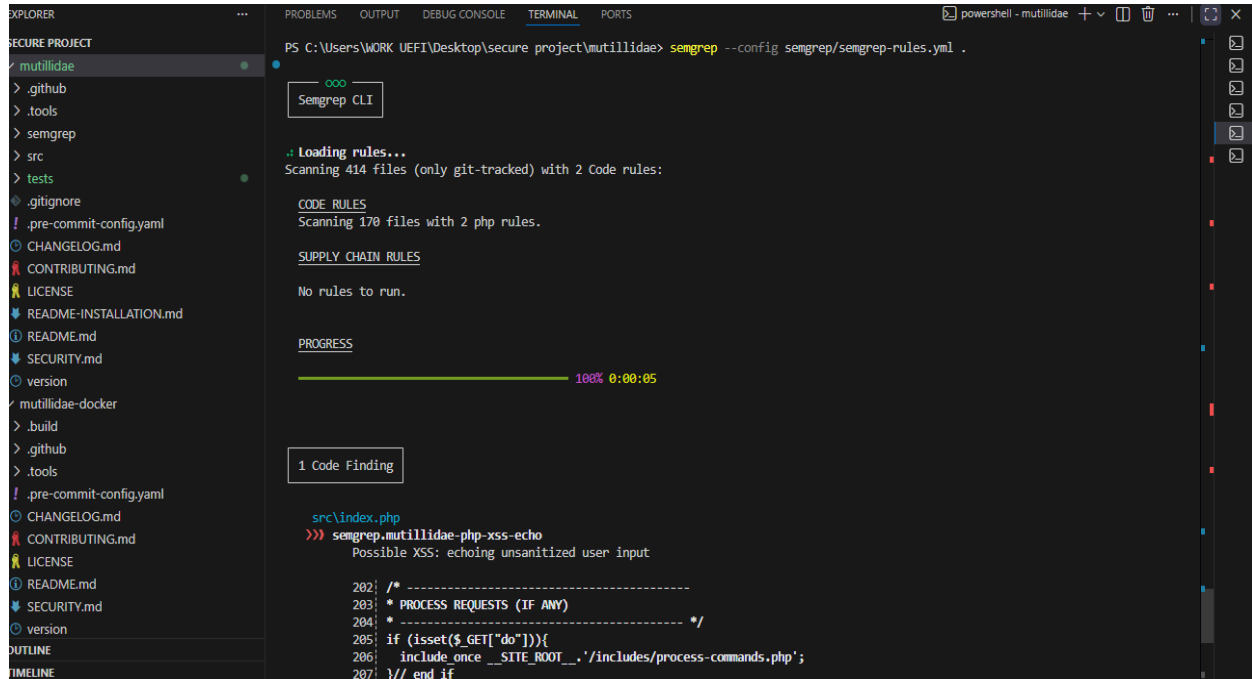
3.*2files in semgrep folder/

```
PS C:\Users\WORK UEFI\Desktop\secure project> cd "C:\Users\WORK UEFI\Desktop\secure project\mutillidae\semgrep"
PS C:\Users\WORK UEFI\Desktop\secure project\mutillidae\semgrep> dir

Directory: C:\Users\WORK UEFI\Desktop\secure project\mutillidae\semgrep

Mode                LastWriteTime         Length Name
----                -
d-----          11/24/2025   2:20 PM             tests
-a----          11/24/2025   2:43 PM           606 semgrep-rules.yml
```

*scan the mutillidae /



```
PS C:\Users\WORK\UEFI\Desktop\secure project\mutillidae> semgrep --config semgrep/semgrep-rules.yml .

Loading rules...
Scanning 414 files (only git-tracked) with 2 Code rules:

CODE RULES
Scanning 170 files with 2 php rules.

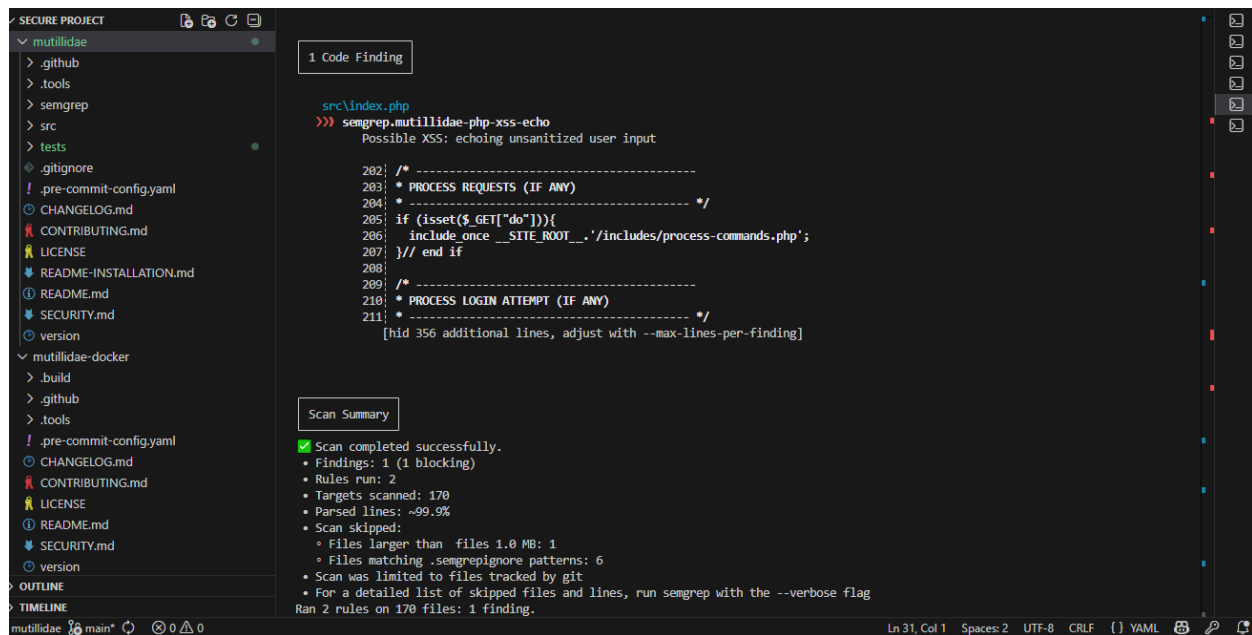
SUPPLY CHAIN RULES
No rules to run.

PROGRESS
100% 0:00:05

1 Code Finding

src\index.php
>>> semgrep.mutillidae-php-xss-echo
Possible XSS: echoing unsanitized user input

202: /* -----
203:  * PROCESS REQUESTS (IF ANY)
204:  * ----- */
205: if (isset($_GET["do"])){
206:     include_once __SITE_ROOT__."/includes/process-commands.php";
207: }// end if
```



```
1 Code Finding

src\index.php
>>> semgrep.mutillidae-php-xss-echo
Possible XSS: echoing unsanitized user input

202: /* -----
203:  * PROCESS REQUESTS (IF ANY)
204:  * ----- */
205: if (isset($_GET["do"])){
206:     include_once __SITE_ROOT__."/includes/process-commands.php";
207: }// end if
208:
209: /* -----
210:  * PROCESS LOGIN ATTEMPT (IF ANY)
211:  * ----- */
[hid 356 additional lines, adjust with --max-lines-per-finding]

Scan Summary
✔ Scan completed successfully.
• Findings: 1 (1 blocking)
• Rules run: 2
• Targets scanned: 170
• Parsed lines: ~99.9%
• Scan skipped:
  • Files larger than files 1.0 MB: 1
  • Files matching .semgreignore patterns: 6
• Scan was limited to files tracked by git
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
Ran 2 rules on 170 files: 1 finding.
```